
Information Security and Access Control Policy

Application: Nolan Net Worth Tracker

Owner: Nolan Chu

Version: 1.0

Effective date: March 18, 2026

Purpose	This document describes the minimum information security controls for a private, single-user application that collects read-only financial account data for personal net worth tracking.
Scope	The policy applies to source code, credentials, CI workflows, local development environments, and any account data retrieved from connected providers.
Data use	The application is for personal use only. It does not initiate payments, transfers, lending decisions, or sharing of consumer data with third parties.

1. Governance and responsibilities

- Nolan Chu is the owner, developer, and security contact for the application and is responsible for maintaining this policy and the controls described below.
- This policy is reviewed at least annually and whenever there is a material change to the application architecture, hosting model, or connected data sources.

2. Access control

- Access to source code repositories, CI configuration, provider dashboards, and stored account data is limited to the owner only. Shared accounts are not used for administration.
- Administrative access follows least-privilege principles. Only the permissions required to develop, run, and maintain the application are enabled.
- Secrets such as API keys, user secrets, and tokens are stored in environment variables or GitHub Actions secrets and are not committed to source control.
- Multi-factor authentication is enabled on critical administrative accounts, including GitHub, the primary email account used for account recovery, and financial-data provider dashboards when supported.
- Access is reviewed periodically, at least quarterly, to confirm that only the intended owner account retains access to repositories, workflows, provider dashboards, and stored data.

-
- If a credential is exposed or compromise is suspected, the affected credential is rotated promptly and any impacted workflow is disabled until the issue is contained.
 - Non-human access uses provider-issued API credentials, OAuth tokens, or equivalent authenticated HTTPS connections as supported by each service.

3. Data handling and minimization

- The application requests only the data needed for personal net worth tracking, primarily account balances, account metadata, and investment account values.
- The application operates in read-only mode and does not move money, initiate transfers, or modify consumer financial accounts.
- Collected data is minimized to the smallest practical set needed for daily historical snapshots and simple reporting.
- Stored records are limited to private local files and private repositories controlled by the owner. Public exposure of collected data is not permitted.

4. Secure development and change management

- The source repository is private. Changes are made by the owner only.
- Dependencies and runtime packages are kept reasonably current. Security-related issues reported by the package manager, operating system, hosting platform, or repository security tooling are reviewed and addressed within a defined service level objective: critical and high-severity issues as soon as practical and targeted within 7 days; medium issues within 30 days; low issues during normal maintenance.
- End-of-life or unsupported software is avoided where practical and replaced during normal maintenance when identified.

5. Network and transport security

- Data exchanged with third-party providers is transmitted over HTTPS using modern TLS as provided by those services and the application runtime environment.
- The application does not intentionally transmit credentials or financial data over plaintext channels.

6. Retention, deletion, and incident handling

- Historical snapshot data is retained only for personal tracking needs and may be deleted by the owner at any time.
- If the application is discontinued, provider tokens and secrets will be revoked or rotated and locally stored data will be deleted when no longer needed.
- In the event of a suspected security incident, the owner will disable automation, rotate exposed credentials, review recent changes and logs, and delete or regenerate affected local data as appropriate.

Certification

This document is intended to describe the current operating practices for a private personal-use application and will be updated if the application scope or operating model changes.